

# Plan de Sécurité de l'Information pour ACT

Protéger nos actifs critiques et garantir la continuité des opérations



## Présenté:

- Franck Enoh
- Claude Kalawa TIZE
- Wilfried Fina Kouede
- Yannick POKAM TAKOUDJOU
- Frantz joel Manga

## Professeur:

Chadi Dlimi



# Introduction

## 01 — Présentation de ACT

- "À Couteaux Tirés" (ACT) est un commerce spécialisé dans la vente au détail de petits articles de cuisine.
- Importance de la sécurité de l'information pour protéger les données clients et assurer la continuité des opérations.

## 02 — Objectifs de la présentation

- Proposer un programme de sécurité pour protéger les actifs de l'entreprise.

# Pourquoi la Sécurité de l'Information est Cruciale ?



## Évolution des menaces cybernétiques

- Augmentation des cyberattaques : ransomware, phishing, DDoS.
- Complexité croissante des attaques et nécessité de mesures de sécurité robustes.



## Impacts potentiels des violations de sécurité :

- Financier : Pertes de revenus, coûts de réparation.
- Opérationnel : Interruption des services.
- Réputationnel : Perte de confiance des clients.
- Légal : Amendes et sanctions pour non-conformité.



**Importance de la confiance des clients et de la conformité réglementaire.**

# Exemple d'Entreprise en Faillite Due à une Sécurité Inadéquate

Entreprise: **Enron**

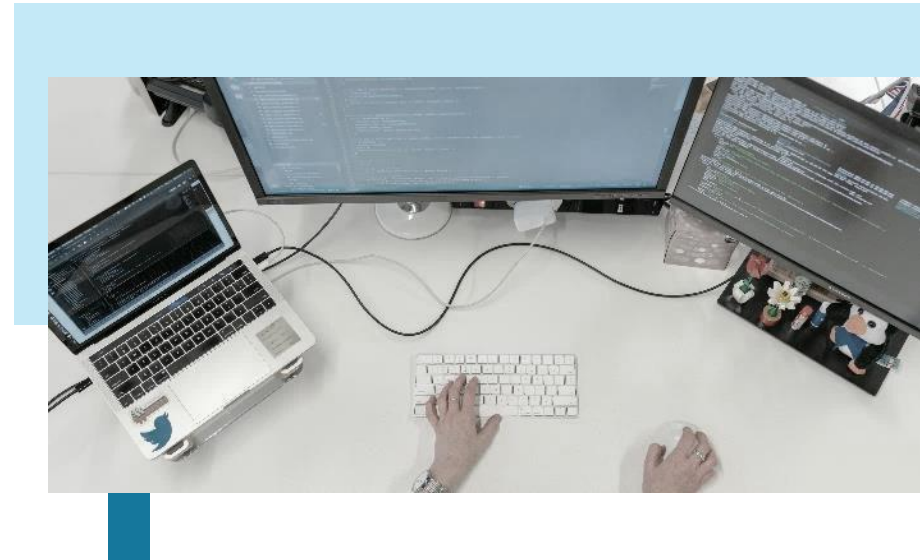
Année de Faillite: **2001**

Cause:

- Fraude comptable massive et mauvaise gestion des risques

Conséquences:

- Perte de confiance des investisseurs,
- Effondrement de l'entreprise,
- Impact légal
- Milliers d'emplois perdus,
- Economies de retraite anéanties



# Actifs Informationnels Critiques d'ACT

## Les Actifs



Données Clients



Système de  
gestion des vente



Serveur de base  
de données



Équipement  
Physique



Personnel TI

# Identification des Menaces et Vulnérabilités



## Actifs

## Vulnérabilités

## Scénarios de Risques

- Données clients

- Données stockées sans chiffrement, contrôles d'accès insuffisants
- Mauvaise configuration des systèmes de sécurité, transmission non sécurisée

- Vol de données clients non chiffrées
- Fuite accidentelle des données clients

- Système de gestion des ventes

- Logiciels non mis à jour, mauvaise configuration des systèmes
- Mauvaise configuration, erreurs de saisie de données.

- Attaque DDoS paralysant le système de gestion des ventes
- Manipulation des données de vente

- Serveur de Base de données

- Manque de patches de sécurité, permissions excessives
- Sauvegardes non sécurisées, absence de plan de reprise après sinistre

- Exploitation d'une vulnérabilité d'injection SQL
- Dommages aux serveurs de base de données causés par une inondation

- Équipement physique

- Absence de maintenance préventive
- Accès physique non contrôlé

- Dégradation ou panne matériel
- Vol des équipements

- Personnel TI

- Sensibilisation insuffisante
- Contrôle manuel inefficace

- Phishing ciblant les identifiants administratifs
- mauvaise configuration de système

# Évaluation des Risques

| Actif                         | Description                                                                                            | Vulnérabilités                                                              | Scénarios de Risque                                                | Code scénario | Type Impact   | Impact (I) | Prob (P) | Niveau de Risque (IxP) | Evaluation de risque |
|-------------------------------|--------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------|--------------------------------------------------------------------|---------------|---------------|------------|----------|------------------------|----------------------|
| Données clients               | Informations personnelles, historiques d'achats, Informations bancaire.                                | Données stockées sans chiffrement, contrôles d'accès insuffisants           | Vol de données clients non chiffrées                               | SR01          | Réputationnel | 4          | 4        | 16                     | Critique             |
|                               |                                                                                                        | Mauvaise configuration des systèmes de sécurité, transmission non sécurisée | Fuite accidentelle des données clients                             | SR02          | Légal         | 4          | 2        | 8                      | Modéré               |
| Système de gestion des ventes | Logiciel utilisé pour la gestion des commandes, des réceptions de marchandises et des suivis de vente. | Logiciels non mis à jour, mauvaise configuration des systèmes               | Attaque DDoS paralysant le système de gestion des ventes           | SR03          | Opérationnel  | 2          | 3        | 6                      | Modéré               |
|                               |                                                                                                        | Mauvaise configuration, erreurs de saisie de données.                       | Manipulation des données de vente                                  | SR04          | Financier     | 3          | 2        | 6                      | Modéré               |
| Serveur de Base de données    | Contient les bases de données pour le système de gestion des ventes                                    | Manque de patches de sécurité, permissions excessives                       | Exploitation d'une vulnérabilité d'injection SQL                   | SR05          | Opérationnel  | 4          | 3        | 12                     | Elevé                |
|                               |                                                                                                        | Sauvegardes non sécurisées, absence de plan de reprise après sinistre       | Dommages aux serveurs de base de données causés par une inondation | SR06          | Opérationnel  | 4          | 1        | 4                      | Faible               |
| Equipement physique           | Matériel Informatique                                                                                  | Absence de maintenance préventive                                           | Dégradation ou panne matériel                                      | SR07          | Opérationnel  | 4          | 3        | 12                     | Elevé                |
|                               |                                                                                                        | Accès physique non contrôlé                                                 | Vol des équipement                                                 | SR08          | Opérationnel  | 2          | 3        | 6                      | Modéré               |
| Personnel TI                  | Administrateur et techniciens supervisant les systemes                                                 | Sensibilisation insuffisante                                                | Phishing ciblant les identifiants administratifs                   | SR09          | Financier     | 3          | 3        | 9                      | Elevé                |
|                               |                                                                                                        | Contrôl manuel inefficace                                                   | mauvaise configuration de système                                  | SR10          | Opérationnel  | 4          | 4        | 16                     | Critique             |



## Matrice avant contre-mesure

| Probabilité | impacts         |             |        |        |       |            |
|-------------|-----------------|-------------|--------|--------|-------|------------|
|             |                 | Négligeable | mineur | Moderé | Grave | Très grave |
|             | Presque certain |             |        |        | SR09  | SR01       |
|             | très probable   |             |        | SR04   | SR07  | SR10       |
|             | possible        |             | SR03   | SR02   | SR05  |            |
|             | improbable      |             | SR08   |        |       |            |
|             | rare            |             |        |        | SR06  |            |



# Contre-Mesures Proposées



| Actif                         | Scénarios de Risque                                                | Code scénario | Evaluation de risque | Contre-Mesures                                                                                                                            | cout   | temps  | Personnel |
|-------------------------------|--------------------------------------------------------------------|---------------|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------|--------|--------|-----------|
| Données clients               | Vol de données clients non chiffrées                               | SR01          | Critique             | Implémenter le chiffrement des données (AES 256) - Renforcer les contrôles d'accès (RBAC, MFA)                                            | \$\$   | 1 mois | TI        |
|                               | Fuite accidentelle des données clients                             | SR02          | Modéré               | Formation régulière sur les bonnes pratiques de sécurité - Mise en place de procédures de vérification par des pairs                      | \$     | 1 mois | TI        |
| Système de gestion des ventes | Attaque DDoS paralysant le système de gestion des ventes           | SR05          | Modéré               | Déployer des solutions anti-DDoS - Configurer des réseaux résilients                                                                      | \$\$\$ | 2 mois | TI        |
|                               | Manipulation des données de vente                                  | SR06          | Modéré               | Implémenter des contrôles d'accès stricts et des audits réguliers                                                                         | \$\$   | 1      | TI        |
| Serveur de Base de données    | Exploitation d'une vulnérabilité d'injection SQL                   | SR07          | Elevé                | Appliquer des patches de sécurité réguliers -- Utiliser des techniques de codage sécurisées (pare-feu applicatif, validation des entrées) | \$     | 2      | TI        |
|                               | Dommages aux serveurs de base de données causés par une inondation | SR08          | Faible               | Mettre en place des sauvegardes régulières et sécurisées -- Élaborer un plan de reprise après sinistre                                    | \$\$   | 1      | TI        |
| Équipement physique           | Dégradation ou panne matériel                                      | SR13          | Elevé                | Mettre en place un contrat de maintenance avec un prestataire                                                                             | \$\$   | 1 mois | TI        |
|                               | Vol des équipement                                                 | SR14          | Modéré               | sécuriser les salles serveur avec des accès restreints                                                                                    | \$\$   | 1 mois | TI        |
| Personnel TI                  | Phishing ciblant les identifiants administratifs                   | SR15          | Elevé                | Formation sur la sécurité, activer l'authentification MFA                                                                                 | \$\$   | 2 mois | TI        |
|                               | mauvaise configuration de système                                  | SR16          | Critique             | Implémenter un audit regulier de configuration                                                                                            | \$     | 1 mois | TI        |

## ESTIMATION DES RESSOURCES

### Coût:

\$ : Faible coût (jusqu'à 5,000 \$)

\$\$ : Coût modéré (entre 5,000 \$ et 20,000 \$)

\$\$\$ : Coût élevé (plus de 20,000 \$)

### Temps:

Court terme : 1 mois ou moins

Moyen terme : 1 à 3 mois

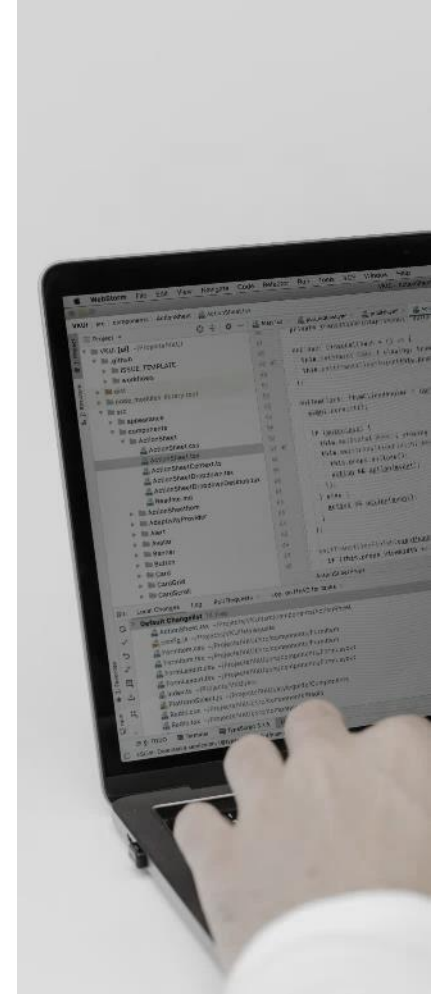
Long terme : Plus de 3 mois

### Personnel:

Nombre de personnes nécessaires pour la mise en œuvre (IT, RH)

# Matrice de risque Après Contre-Mesure

| Probabilité | impacts         |             |        |        |       |            |
|-------------|-----------------|-------------|--------|--------|-------|------------|
|             |                 | Négligeable | Mineur | Modéré | Grave | Très grave |
|             | Presque certain |             |        |        |       |            |
|             | très probable   |             |        |        |       |            |
|             | possible        | SR10        | SR03   | SR02   |       |            |
|             | improbable      | SR01        | SR08   | SR04   | SR05  |            |
|             | rare            |             | SR07   | SR09   | SR06  |            |
|             |                 |             |        |        |       |            |



# Coût Global de Mise en Œuvre du Programme de Sécurité



| Contre-Mesures                                                                                                                            | coût                 | temps           | Personnel                        |
|-------------------------------------------------------------------------------------------------------------------------------------------|----------------------|-----------------|----------------------------------|
| Implémenter le chiffrement des données (AES 256) - Renforcer les contrôles d'accès (RBAC, MFA)                                            | 15 000,00 \$         | 1 mois          | 2 à 3 TI                         |
| Formation régulière sur les bonnes pratiques de sécurité - Mise en place de procédures de vérification par des pairs                      | 15 000,00 \$         | 1 mois          | 1-3 TI                           |
| Déployer des solutions anti-DDoS - Configurer des réseaux résilients                                                                      | 30 000,00 \$         | 2 mois          | 2-3 TI                           |
| Implémenter des contrôles d'accès stricts et des audits réguliers                                                                         | 20 000,00 \$         | 1 mois          | 2-3 TI                           |
| Appliquer des patches de sécurité réguliers -- Utiliser des techniques de codage sécurisées (pare-feu applicatif, validation des entrées) | 20 000,00 \$         | 2 mois          | 3-4 TI                           |
| Mettre en place des sauvegardes régulières et sécurisées -- Élaborer un plan de reprise après sinistre                                    | 20 000,00 \$         | 1 mois          | 2-3 TI                           |
| Mettre en place un contrat de maintenance avec un prestataire                                                                             | 10 000,00 \$         | 1 mois          | 1 TI                             |
| sécuriser les salles serveur avec des accès restreints                                                                                    | 10 000,00 \$         | 1 mois          | 1-2 TI                           |
| Formation sur la sécurité, activer l'authentification MFA                                                                                 | 5 000,00 \$          | 2 mois          | 1-2 TI                           |
| Implémenter un audit régulier de configuration                                                                                            | 5 000,00 \$          | 1 mois          | 2-3 TI                           |
| <b>TOTAL</b>                                                                                                                              | <b>150 000,00 \$</b> | <b>6/8 Mois</b> | <b>Variable selon les taches</b> |

# Plan d'exécution

---

# Conclusion Générale

---

La sécurité de l'information est cruciale pour ACT afin de protéger les données sensibles, maintenir la confiance des clients et se conformer aux réglementations. Notre programme de sécurité propose des mesures spécifiques telles que le chiffrement des données et le renforcement des contrôles d'accès. L'investissement dans ce programme garantira une meilleure protection des actifs, une réduction des risques et une continuité des opérations. Votre soutien est essentiel pour mettre en œuvre ces mesures et assurer la résilience future de l'entreprise.



# Thank You



Equipe Cybersecurity :

- **Franck Enoh** : [franckenoh24@gmail.com](mailto:franckenoh24@gmail.com)
- **Claude Kalawa TIZE** : [tize.formationen@gmail.com](mailto:tize.formationen@gmail.com)
- **Wilfried Fina Kouede** : [wilffina@gmail.com](mailto:wilffina@gmail.com)
- **Yannick POKAM TAKOUDJOU** : [yannick1.pokam@gmail.com](mailto:yannick1.pokam@gmail.com)
- **Frantz joel Manga** : [frantzjoelm@gmail.com](mailto:frantzjoelm@gmail.com)